GitHub identity & access
Solution options and decision paper

hi3g-enterprise | Five organizations | Approximately 189 users | Existing enterprise-funded Copilot

Draft for stakeholders and sponsors. Based on the described environment, not a tenant inspection. Contract terms, current SSO scope, Copilot plan and complete domain list require validation.

Decision in brief

Two practical routes can improve repository access: strengthen the existing enterprise without moving repositories, or adopt Enterprise Managed Users (EMU) through a replacement enterprise and migration. Both can provide group-driven repository entitlements. Only EMU provides company-managed GitHub accounts and excludes personal accounts from the target.

Current state and desired outcome

Most users access GitHub through personal accounts linked to Entra SSO; SSO was described as configured but not enforced. Organization base permission is Write, so team membership does not isolate repositories. On-premises Windows AD already synchronizes identities and groups to Entra ID. The target is corporate authentication, approved identities, assigned-only repository visibility and reliable group-driven onboarding/offboarding.

Route	When it fits	Principal limitation
1. Existing-enterprise hardening	Improve access with less transition work and retained identities/URLs.	Personal GitHub accounts remain.
2. EMU migration	Company ownership of accounts and no personal-account access are mandatory.	New identities and migration/integration work.
Phased strategy	Reduce current risk while confirming an eventual EMU decision.	Adds overall transition effort; not a third identity model.

Recommended decision

If no personal accounts is mandatory, select EMU subject to costs and pilot acceptance. If corporate SSO and restricted repository access are sufficient, hardening is a credible alternative with an explicitly accepted personal-account exception.

Authorize discovery and pilot first, not an unquoted full rollout. Planning estimates: 4-6 weeks for hardening; approximately 12 weeks for EMU. Neither guarantees zero interruption.

1. Option 1 - Strengthen the existing enterprise

Solution and implementation

Retain organizations, repositories, URLs, user identities and existing Copilot assignments. Enforce Entra SAML SSO, synchronize approved groups to GitHub teams, set explicit repository roles, use private repositories and reduce organization base permission to None.

AD controls membership of synchronized groups; Entra is the IdP; GitHub configures team-to-repository access. SSO remains an additional authentication requirement: users continue to sign into personal GitHub accounts. Restrict corporate IdP eligibility and approved email attributes, but do not describe this as ownership of the GitHub account.

Benefits

Benefit	Business significance
No repository migration	Preserve URLs and most integration structure; lower transition scope.
Least privilege in place	Remove default Write and restrict users to approved private repositories.
Group-based entitlements	Reduce manual team membership updates and make approvals auditable.
Existing Copilot identities retained	Avoid a managed-account reassignment solely for identity migration.
External collaboration retained	Personal accounts can continue approved public/partner work.

Complications and limits

Personal-account SCIM requires organization-level SAML, not enterprise-level SAML. First confirm the scope of the current SSO configuration. If it is enterprise-level, changing architecture is a separate approved project; do not assume organization SCIM can simply be added. It provisions organization access, not GitHub accounts.

Team synchronization is not complete account provisioning or organization offboarding. Users generally need existing organization membership and a linked SSO identity. Linking teams can remove users who do not meet prerequisites; pilot before rollout.

Existing manually invited users must be reconciled with SCIM identities. SAML NameID and SCIM userName must match. Provisioning depends on an authorized integration account whose lifecycle and permissions need protection.

Corporate-email work accounts are still personal accounts. SSO alone is not sufficient offboarding: verify organization membership removal and credential access denial.

2. Option 1 - Delivery, impact and acceptance

Window	Activity	Evidence
Week 1	Inventory identities, SSO scope, grants, repositories and automation.	Validated architecture and dependencies.
Week 2	Approve access matrix and provisioning/team-sync design.	App owners approve required access.
Week 3	Pilot identity linking, SSO enforcement and team synchronization.	No unexpected loss of required access.
Week 4	Apply explicit grants, private visibility and base None in waves.	Assigned-only access confirmed.
Weeks 5-6	Complete lifecycle rollout, exceptions and operational handover.	Offboarding evidence and owned runbooks.

Continuity approach

Prepare explicit grants before removing base Write. Keep existing access until prerequisites are confirmed. Communicate intentional reductions separately from accidental loss of required access. Treat SSO enforcement, team connections and any visibility changes as controlled changes, not harmless toggles.

Test PAT/SSH authorization, apps, deploy keys, runner access and cross-repository dependencies. Changing repository visibility can affect forks and consumers; assess beforehand. Authentication and permission changes can break automation even without migration.

Acceptance

Approved SSO works; unapproved IdP identities cannot authenticate to protected resources. Assigned private repositories are accessible at intended roles; unassigned repositories are absent from lists/search and denied by direct URL/API/clone. Group addition/removal behaves correctly. Organization offboarding is demonstrated, not inferred from group removal.

Critical builds/deployments and existing Copilot access pass. Personal-account ownership remains a documented exception approved by the sponsor/security owner.

Cost considerations

Repository migration costs are avoided, but staffing, Entra entitlements, dedicated provisioning identity requirements and integration work may still cost money. Existing GitHub/Copilot subscriptions remain subject to contract and usage. No quoted savings or guaranteed unchanged bill is asserted.

3. Option 2 - Enterprise Managed Users

Solution and implementation

GitHub's documented adoption path from personal accounts requires migration to a new EMU enterprise account. This is a replacement environment; existing personal accounts are not converted. Retain the five-organization business structure and provision managed accounts from Entra through authentication and SCIM.

Reuse existing AD-to-Entra synchronization. Link appropriate Entra security groups to GitHub teams, configure team-to-repository roles and enforce private visibility/base None. Evaluate Entra OIDC or supported SAML against tenant requirements.

Benefits

Benefit	Business significance
Company-controlled accounts	Personal identities cannot access the target enterprise.
Corporate authentication authority	Managed identities authenticate through the corporate IdP.
IdP-controlled profile attributes	Corporate account email/profile lifecycle is managed centrally.
Enterprise SCIM lifecycle	Provision, update and suspend managed accounts through Entra.
Group-driven entitlements	Link groups to teams/organizations with approved repository roles.

Complications and limits

Users receive new identities and must transition Git/IDE credentials and Copilot access. Migration requires attention to URLs, apps, cloud deployment trust, runners and settings. GitHub's importer does not carry all secrets, runtime history, packages, LFS objects, rulesets or user credentials; validate coverage and restore separately.

Managed accounts cannot contribute outside the enterprise or create public organization repositories. Approve a separately governed personal-account workflow for external work, without granting it access to the target. Contractors need approved managed identities.

Group-linked EMU teams must be flat; Entra security groups require supported direct membership. Corporate-domain eligibility needs IAM/provisioning controls, not just GitHub domain verification. Directory and SCIM changes have propagation delays.

A new account does not automatically require a second permanent subscription, but temporary coexistence and current entitlement application require written GitHub agreement.

4. Option 2 - Delivery, continuity and Copilot

Window	Activity	Exit condition
Weeks 1-3	Confirm vendor terms; inventory and approve identity/access design.	Supported path, ownership and access matrix.
Weeks 4-5	Build EMU/SCIM and prepare a small-org pilot with integrations.	Target ready; source remains authoritative.
Week 6	Rehearse access, migration, lifecycle, build/deployment and Copilot.	Pilot acceptance tests pass.
Week 7	Cut over pilot organization; provide hypercare.	Real users and production workflows accepted.
Week 8	Resolve findings, finalize costs and approve remaining waves.	Sponsor rollout decision.
Weeks 9-10	Migrate the remaining four organizations by dependency.	Owner acceptance for each wave.
Weeks 11-12	Reconcile access/credentials; retention and handover.	Approved retirement and operational closure.

Protect production

Build the target in parallel without changing source access, credentials, runners or integrations initially. Rehearse in isolated test environments; disable target production schedules/webhooks/deployment triggers to prevent duplicate execution.

Agree the final write-freeze window after rehearsal; let active jobs complete, migrate, restore configuration and validate before opening target writes and automation. Only one production write/deployment authority at a time. Post-write rollback needs reconciliation.

Copilot and commercial controls

EMU supports enterprise-funded Copilot; an upgrade from Business to Enterprise is not required solely for EMU. Confirm the current offering, assigned seats and contract; 189 GitHub users does not imply 189 Copilot seats. New managed identities need target assignments and IDE sign-in; pilot before removing old access.

Do not assume automatic seat transfer, deduplication of personal/managed identities or free overlap. Confirm Enterprise/Copilot entitlement application, coexistence duration, duplicate-seat billing, usage budgets, migration-service charges and Entra entitlements.

Pilot acceptance

Personal-account target access denied; approved corporate managed sign-in works. Unapproved-domain provisioning blocked. Assigned-only repository visibility and direct access denial pass. AD/Entra changes reach intended team access and full account suspension. Critical pipelines and Copilot work; recovery and data reconciliation pass.

5. Comparison and decision considerations

Consideration	Existing-enterprise hardening	EMU migration
Exclude personal accounts	No; personal identity remains.	Yes, in target.
Corporate authentication	SSO alongside personal login.	Corporate IdP for managed identity.
Corporate account/email control	IdP eligibility, not GitHub account ownership.	IdP-controlled managed attributes.
Assigned-only repo visibility	Private + base None + explicit grants.	Private + base None + explicit grants.
Lifecycle automation	Team sync + supported org SCIM; reconcile identities.	Enterprise SCIM + group-linked teams.
Repository/URL transition	No migration; retained URLs.	Migration/naming plan required.
Copilot transition	Existing identities retained.	New assignments and IDE reauthentication.
External collaboration	Retained, subject to policy.	Separate governed workflow.
Delivery complexity	Lower, but not risk-free.	Higher; parallel build and cutover.
Indicative duration	4-6 weeks, subject to discovery.	About 12 weeks, subject to discovery.

Controls common to both

Base None alone does not hide internal repositories from regular enterprise members. Private visibility and explicit grants are required. Privileged owners/admin roles can have broader access and must be separately governed. Permissions are additive.

Organization-wide access groups cannot isolate project repositories; create narrower entitlement groups where needed. AD owns synced group membership; GitHub defines repository roles. Monitor synchronization errors and alternative access paths.

Approve exact corporate domains (tre.se, 3.dk and the validated German domain), authoritative mail/UPN mappings, contractor expiry and recovery procedures. Neither solution erases already-cloned code or makes app/deploy-key access identical to human SSO.

Choice and trade-off

Choose hardening if sponsors accept personal accounts and prioritize lower transition work. Choose EMU if company account ownership and no personal identities are mandatory. A harden-first/EMU-later strategy reduces current risk but adds elapsed time and repeated transition work; plan which groups and permissions can be reused.

6. Sponsor approvals and governance

Decision gates

Gate	Sponsor evidence
1. Discovery/pilot approval	Required account-ownership policy, owners, capacity and approved pilot scope.
2. Solution/production approval	Architecture, final costs, pilot results, recovery and accepted exceptions.
3. Wave acceptance	Required access, lifecycle, data and critical pipelines validated by app owners.
4. Closure	Residual access reconciled, credentials retired where applicable, retention and support in place.

Owners and measures

Sponsor owns funding and risk acceptance. IAM owns AD/Entra eligibility, SSO and lifecycle. Platform owns GitHub roles and integrations. Security owns control assurance. Application owners approve access and deployment readiness. Procurement confirms GitHub/Copilot terms. Service desk supports account changes.

Measure successful approved onboarding, absence of unassigned private-repo access, verified revocation, critical pipeline success and provisioning errors. Agree lifecycle SLAs after measuring propagation; do not promise instantaneous offboarding. Review privileged access monthly and entitlements quarterly as proposed policy.

Outstanding confirmations

SSO enterprise/organization scope; full group/member mapping; tenant/sync configuration; repository/integration inventory; approved domains; current Copilot offering and seats; vendor terms and naming; test environments; cutover/recovery windows.

Official guidance

Enterprise type / EMU migration: https://docs.github.com/en/enterprise-cloud@latest/admin/concepts/enterprise-fundamentals/choose-an-enterprise-type

Personal-account organization SCIM: https://docs.github.com/en/enterprise-cloud@latest/organizations/managing-saml-single-sign-on-for-your-organization/about-scim-for-organizations

Personal-account team synchronization: https://docs.github.com/en/enterprise-cloud@latest/organizations/organizing-members-into-teams/synchronizing-a-team-with-an-identity-provider-group

EMU group-linked teams: https://docs.github.com/en/enterprise-cloud@latest/admin/managing-iam/provisioning-user-accounts-with-scim/managing-team-memberships-with-identity-provider-groups

Migration coverage: https://docs.github.com/en/migrations/using-github-enterprise-importer/migrating-between-github-products/about-migrations-between-github-products

Copilot licensing: https://docs.github.com/en/billing/concepts/product-billing/github-copilot-licenses